

Proyecto 2 - Historia Clinica

Jery / Chory

Preguntas 2 y 5: auditoria, seguridad e integracion

Entrega integrada | 9 de octubre de 2026

Auditoria automatica y transaccional

Auditar identifica las operaciones de registro, modificacion y eliminacion. AuditoriaAspect intercepta servicios anotados y registra usuario autenticado, fecha/hora, operacion, entidad e ID del registro en auditoria_registros.

El aspecto ejecuta la operacion y su evento dentro de la misma transaccion. Si falla la operacion, no se registra un exito; si falla la persistencia de auditoria, se revierte tambien el cambio de negocio. Las lecturas no producen eventos.

El usuario se obtiene del principal autenticado, no de un nombre enviado en el JSON. Instant representa el tiempo y la pantalla lo etiqueta UTC. La bitacora almacena metadatos y no contraseñas ni cuerpos clinicos completos.

registro_id no tiene clave foranea al objeto eliminado: la evidencia debe sobrevivir a la eliminacion. En eliminaciones por cascada se registra la entidad principal, no se afirma un evento independiente por cada hijo.

La vista /auditoria y GET /api/auditoria son solo para administrador y estan paginadas. En la demostracion quedaron 19 operaciones con actor admin, incluyendo registro, modificacion y eliminacion.

Seguridad y flujo integrado

Spring Security implementa login web, logout POST y HTTP Basic para Postman. CSRF permanece activo; los formularios Thymeleaf incluyen el token y el frontend/API lo obtiene mediante GET /api/csrf.

ADMINISTRADOR tiene acceso clinico, usuarios, roles y auditoria. MEDICO accede a pacientes e informacion clinica, sin administracion. RECEPCIONISTA registra y consulta pacientes, sin historias ni datos clinicos. No se agrego un modulo de citas que el sistema anterior no tenia.

Los menus usan autorizacion por rol y el backend aplica los mismos limites. Un usuario no obtiene acceso solo por escribir una URL. Las API sin autenticacion devuelven 401 y una cuenta sin permiso recibe 403.

VigenciaUsuarioFilter revalida cuenta y rol en cada solicitud. Desactivar un usuario o rol corta tambien una sesion ya iniciada. El perfil demo crea cuentas solamente si no existen y toma sus claves de variables de entorno.

La integracion mantiene una sola aplicacion raiz, una base historia_clinica y las entidades compartidas. El respaldo antecedentes se conserva. Las consultas medicas se relacionan con SignosVitales (OneToOne) y Diagnostico (OneToMany/ManyToOne), ademas de tratamientos y evoluciones.

Guion y demostracion tecnica

Guion: Mi parte une auditoria y control de acceso con la Atencion Medica existente. La auditoria acompaña cada cambio en la misma transaccion. La seguridad verifica roles en el servidor y en el menu; las sesiones se invalidan si la cuenta o su rol se desactivan.

Demostrar como admin una consulta medica, sus signos vitales y un diagnostico ficticio. Modificar el diagnostico y eliminar solamente ese registro de prueba. Abrir Auditoria y comprobar actor, accion, entidad e ID.

En Postman mostrar medico-administracion = 403, recepcion-historia = 403, recepcion-pacientes = 200 y escritura sin CSRF = 403. La coleccion y sus pruebas automatizadas ofrecen evidencia reproducible.

¿Por que CSRF con login? El navegador envia cookies automaticamente; el token ayuda a impedir escrituras originadas desde otra pagina. Desactivarlo globalmente no es una solucion de integracion.

¿Como se prueba rollback? Las pruebas de auditoria provocan un fallo y comprueban que no persistan ni el cambio ni un evento de exito. H2 se usa en tests; MySQL/MariaDB en la ejecucion local.

Archivos: paquetes auditoria y seguridad, AtencionMedicaService, SeguridadIntegrationTest y AuditoriaIntegrationTest. No presentar esto como un sistema clinico de produccion: quedan fuera despliegue HTTPS, respaldo operativo y evaluacion de seguridad externa.

Ejecucion y evidencia

Clonar <https://github.com/JeryBn/Evaluacion1Coello> y abrir el pom.xml de la raiz. Requisitos: Java 21, Maven y MySQL/MariaDB. No iniciar la carpeta antecedentes como otra aplicacion.

Crear la base historia_clinica e importar database/esquema-proyecto2.sql solamente en una base vacia. El esquema tiene 13 tablas y no publica registros ni claves. En una base existente, respaldar antes de actualizar.

Seguir el README: definir el perfil demo y las tres variables DEMO_ADMINISTRADOR_PASSWORD, DEMO_MEDICO_PASSWORD y DEMO_RECEPCIONISTA_PASSWORD. Iniciar Spring Boot e ingresar con admin, medico o recepcion. Las claves son definidas por quien instala y no se reemplazan si los usuarios ya existen.

Importar postman/Proyecto-2.postman_collection.json y configurar baseUrl y las claves de los tres usuarios. Ejecutar en orden. La coleccion obtiene CSRF antes de las operaciones de escritura y crea datos ficticios.

Resultado comprobado: 13 pruebas automatizadas exitosas. La coleccion ejecutada mediante Newman produjo 47 solicitudes HTTP y 30 aserciones sin fallos. Newman ejecuta el formato Postman; no debe confundirse con una ejecucion manual de su interfaz.

El reparto organiza la exposicion, no cambia la autoria de los commits. La implementacion restante se completo con asistencia de Codex en la copia de Jery. La guia utiliza indicaciones individuales: confirmar con el docente el formato de entrega del grupo.

Evidencia real: auditoria

Captura del entorno local integrado. Datos ficticios de demostracion; sin claves publicadas.

Inicio

Pacientes

Auditoria

Usuarios

Roles

Historias clínicas

Atención médica

← Atrás

Adelante →

admin

Cerrar sesion

Bitacora de auditoria

Operaciones registradas: 19

Usuar io	Fecha y hora (UTC)	Operacion	Entidad	ID del registro
admin	2026-10-09T04:46:28Z	MODIFICACI ON	Antecedente	4
admin	2026-10-09T04:46:28Z	REGISTRO	Antecedente	4
admin	2026-10-09T04:46:27Z	ELIMINACIO N	Diagnostico	5
admin	2026-10-09T04:46:27Z	MODIFICACI ON	Diagnostico	5
admin	2026-10-09T04:46:27Z	REGISTRO	Diagnostico	5
admin	2026-10-09T04:46:27Z	REGISTRO	SignosVítale s	4
admin	2026-10-09T04:46:26Z	REGISTRO	ConsultaMe dica	5
admin	2026-10-09T04:46:26Z	MODIFICACI ON	Atencion	2
admin	2026-10-09T04:46:26Z	REGISTRO	Atencion	2
admin	2026-10-09T04:46:25Z	REGISTRO	HistoriaClini ca	4
admin	2026-10-09T04:46:25Z	REGISTRO	Paciente	5
admin	2026-10-09T04:46:25Z	MODIFICACI ON	Usuario	4
admin	2026-10-09T04:46:25Z	MODIFICACI ON	Usuario	4
admin	2026-10-09T04:46:24Z	MODIFICACI ON	Usuario	4
admin	2026-10-09T04:46:24Z	REGISTRO	Usuario	4
admin	2026-10-09T04:46:24Z	MODIFICACI ON	Rol	4
admin	2026-10-09T04:46:24Z	MODIFICACI ON	Rol	4
admin	2026-10-09T04:46:23Z	MODIFICACI ON	Rol	4
admin	2026-10-09T04:46:23Z	REGISTRO	Rol	4

Pagina 1

Volver a Atencion Medica